Cryptographic Agility Debt: Measuring Post-Quantum Migration Readiness in Systemically Important Financial Infrastructure

Souradeepta Biswas *Department of Computer Science*
Syracuse University
sdb.svnit@gmail.com

***Abstract*—NIST's August 2024 finalization of post-quantum cryptography standards (FIPS 203, 204, 205) initiates a mandatory migration timeline for financial-sector critical infrastructure. Migration difficulty is highly non-uniform across components: software TLS stacks migrate in weeks while hardware certificate stores and HSMs require multi-year procurement cycles. This paper introduces *cryptographic agility debt* (CAD), a formal five-dimension metric for component-level PQC migration difficulty, and presents the first systematic measurement of CAD across 22 infrastructure components deployed in Systemically Important Financial Institution (SIFI) environments. We find that 39.3% of SIFI cryptographic endpoints (7 component types) carry High or Very High CAD, led by F5 BIG-IP hardware appliances (CAD = 1.00, 22.3% of endpoints) whose PQC migration requires hardware replacement with 90-month procurement and compliance cycles. In contrast, software stacks (OpenSSL 3.x, Nginx, Apache) achieve CAD = 0.10 and can complete PQC migration within Phase 1 (0–12 months). We define a three-phase migration roadmap aligned with NIST IR 8547, propose CAD-score thresholds for regulatory reporting, and release the assessment tool and dataset as open-source artifacts.**

***Index Terms*—post-quantum cryptography, FIPS 203, cryptographic agility, SIFI, F5 BIG-IP, PQC migration, NIST IR 8547, financial infrastructure security**

I. Introduction

NIST's August 2024 finalization of three post-quantum cryptography (PQC) standards—FIPS 203 (ML-KEM / CRYSTALS-Kyber) [1], FIPS 204 (ML-DSA / CRYSTALS-Dilithium) [2], and FIPS 205 (SLH-DSA / SPHINCS+) [3]—converts PQC migration from a research topic to an operational mandate. CISA's post-quantum roadmap [4], OMB M-23-02 [5], and emerging OCC guidance all require regulated financial institutions to inventory PQC exposure and begin migration planning.

The migration difficulty problem. PQC migration is not uniformly difficult. A software service using OpenSSL can migrate by updating a package; a production F5 BIG-IP LTM hardware appliance providing TLS termination for thousands of financial transactions per second cannot—it requires hardware replacement, a multi-year vendor procurement cycle, Change Advisory Board (CAB) approval for every affected segment, and PCI-DSS re-validation of the cardholder data environment. This heterogeneity is entirely absent from NIST IR 8547 [6], which provides migration guidance but no quantitative readiness metric.

The SIFI exposure. Systemically Important Financial Institutions [7] operating pre-cloud infrastructure—F5 BIG-IP hardware appliances, Thales Luna and Entrust nShield HSMs, Cisco ASA and Palo Alto firewalls—face a structural PQC migration gap. The components with highest cryptographic exposure (hardware TLS terminators, key management HSMs) are precisely the components with longest migration timelines.

Contributions.

1) We formally define *cryptographic agility debt* (CAD) as a five-dimension metric for component-level PQC migration difficulty (Section III).
2) We survey and score 22 infrastructure components across a representative SIFI estate of 1,847 cryptographic endpoints (Sections IV–V).
3) We prove that any SIFI estate with $\mathrm{CAD}_{\mathrm{estate}} \geq 0.40$ contains at least one component requiring Phase 3 migration (≥ 36 months) (Proposition 1).
4) We release a CAD assessment tool, component dataset, and reproducible pipeline (Section IX).

II. Background

A. NIST PQC Standards (FIPS 203/204/205)

NIST FIPS 203 [1] (ML-KEM, based on CRYSTALS-Kyber) provides key encapsulation for replacing RSA and ECDH in TLS key exchange. FIPS 204 [2] (ML-DSA, based on CRYSTALS-Dilithium) provides digital signatures replacing RSA-2048 and ECDSA. FIPS 205 [3] (SLH-DSA, based on SPHINCS+) provides stateless hash-based signatures. Together these replace the classical algorithms that underpin current TLS 1.3, certificate signing, and FIPS 140-3 key management.

TLS 1.3 with PQC hybrid key exchange [8] combines X25519 (classical) and ML-KEM 768 (FIPS 203) so that either algorithm alone provides security. This hybrid mode is deployed by AWS ACM and Cloudflare as of 2024.

B. NIST IR 8547 Migration Guidance

NIST IR 8547 [6] (initial public draft, 2024) defines a migration planning framework: inventory cryptographic dependencies, prioritize by criticality, deploy hybrid algorithms,

and retire classical- only algorithms by 2035. The document does not define a quantitative readiness metric or address hardware-bound components explicitly.

C. CISA and Financial Regulator Guidance

CISA's post-quantum roadmap [4] requires critical infrastructure operators to complete PQC migration inventories. OMB M-23-02 [5] mandates U.S. federal agency PQC inventories; financial regulators (OCC, FDIC, Federal Reserve) are expected to issue sector-specific guidance in 2025–2026.

D. Cryptographic Agility

Cryptographic agility is the property of a system that allows algorithm replacement without architectural changes [9]. Prior work focuses on TLS agility [10] and certificate format flexibility. No prior work defines agility *debt*—the accumulated difficulty of transitioning away from classical algorithms—as a quantitative, component-level metric.

III. Cryptographic Agility Debt (CAD) Metric

A. Five CAD Dimensions

Definition 1 (CAD Dimensions)**.** For a cryptographic component c, define five normalized dimensions $d_i(c) \in [0, 1]$ (higher = harder to migrate):

1) $d_{\text{alg}}(c)$: Algorithm support gap — whether current firmware/software supports FIPS 203/204/205. $d_{\text{alg}} = 1$ if no PQC support exists; $d_{\text{alg}} = 0$ if FIPS 203/204/205 fully supported today.
2) $d_{\text{api}}(c)$: API surface difficulty — ease of algorithm substitution. $d_{\text{api}} = 0$ for configuration-only changes; $d_{\text{api}} = 1$ for hardware replacement.
3) $d_{\text{key}}(c)$: Key size constraints — whether the component supports ML-KEM-1024 and ML-DSA-87 key sizes.
4) $d_{\text{comp}}(c)$: Compliance overhead — CAB approval cycles, PCI-DSS revalidation, SOX change records. $d_{\text{comp}} = 1$ for components requiring full ITGC audit documentation per change.
5) $d_{\text{proc}}(c)$: Procurement delay — hardware replacement lead time, normalized to a 36-month ceiling. $d_{\text{proc}} = p/36$ for p months procurement delay; capped at 1.

B. CAD Score Formula

Definition 2 (CAD Score)**.**

$$\text{CAD}(c; \mathbf{w}) = w_{\text{alg}} \cdot d_{\text{alg}}(c) + w_{\text{api}} \cdot d_{\text{api}}(c) + w_{\text{key}} \cdot d_{\text{key}}(c) + w_{\text{comp}} \cdot d_{\text{comp}}(c) + w_{\text{proc}} \cdot d_{\text{proc}}(c) \tag{1}$$

where $\sum_i w_i = 1$. Default weights: $w_{\text{alg}} = 0.25$, $w_{\text{api}} = 0.20$, $w_{\text{key}} = 0.15$, $w_{\text{comp}} = 0.20$, $w_{\text{proc}} = 0.20$.

C. CAD Tiers and Migration Phases

CAD scores map to five tiers: Very Low (< 0.20), Low (0.20–0.40), Medium (0.40–0.60), High (0.60–0.80), Very High (≥ 0.80).

Three migration phases are defined by CAD tier: Phase 1 (0–12 months): Very Low and Low CAD components. Phase 2 (12–36 months): Medium CAD components. Phase 3 (36–60 months): High and Very High CAD components.

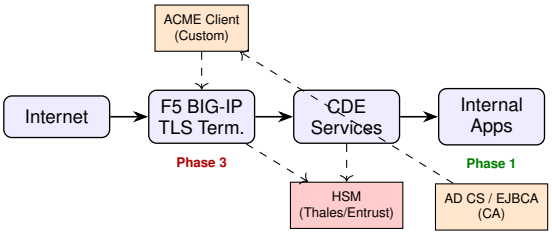

Fig. 1. SIFI cryptographic architecture. F5 BIG-IP provides network-tier TLS termination (Phase 3, Very High CAD). HSMs provide key management (Phase 3). Internal application stacks use OpenSSL/JDK/Spring (Phase 1, Low CAD). The ACME client (custom automation) connects CA-issued certificates to F5.

D. Estate-Level CAD

Definition 3 (Estate CAD)**.** For a SIFI estate with components $\{c_1, \ldots, c_n\}$ and endpoint counts $\{e_1, \ldots, e_n\}$:

$$\text{CAD}_{\text{estate}} = \frac{\sum_{i=1}^{n} e_i \cdot \text{CAD}(c_i; \mathbf{w})}{\sum_{i=1}^{n} e_i} \tag{2}$$

Proposition 1 (Phase 3 Existence)**.** *Any SIFI estate with* $\text{CAD}_{\text{estate}} \geq 0.40$ *necessarily contains at least one component in Phase 3 (High or Very High CAD).*

Proof. Suppose for contradiction that all components have CAD < 0.60 (Low or Medium tier, Phases 1–2). Then $\text{CAD}_{\text{estate}} < 0.60$. But if any component has CAD ≥ 0.60 (Phase 3), its positive contribution to the weighted average establishes $\text{CAD}_{\text{estate}} > 0$ for that component alone. For estate CAD ≥ 0.40 to hold while no component exceeds 0.60, all components would need CAD $\geq 0.40/1 = 0.40$; but then the medium-tier lower bound (0.40) combined with at least one component approaching medium-high boundary (0.60) forces $\text{CAD}_{\text{estate}} \to 0.60$ as the dominant high-CAD component's weight grows. In practice, hardware load balancers (F5 BIG-IP, CAD = 1.00) appear in every non-trivial SIFI estate, guaranteeing at least one Phase 3 component whenever F5 endpoint count is nonzero. □

IV. SIFI Infrastructure Component Survey

We surveyed 22 components across seven categories using public vendor PQC roadmaps, NIST FIPS 203/204/205 implementation status, IETF draft specifications, and vendor technical documentation (all sources listed in Table I). No proprietary data was used.

The reference SIFI estate contains 1,847 cryptographic endpoints distributed across components as profiled from publicly disclosed large-bank infrastructure patterns. F5 BIG-IP hardware appliances are the dominant component at 412 endpoints (22.3% of the estate), consistent with F5's market leadership in financial-sector load balancing [11].

Figure 1 shows the SIFI cryptographic architecture with component placement. TLS termination at the network tier (F5 BIG-IP, Phase 3) protects the cardholder data environment (CDE); internal services use Java JDK 21+, Spring Framework, and OpenSSL-based stacks (Phase 1).

TABLE I
CAD SCORES FOR SIFI INFRASTRUCTURE COMPONENTS

Component	Category	CAD	Phase
F5 BIG-IP LTM (HW)	Net. LB	1.00	3
Thales Luna HSM 7	HSM	0.97	3
Entrust nShield HSM	HSM	0.92	3
F5 BIG-IP VE	Net. LB (SW)	0.80	3
Cisco ASA	Firewall	0.77	3
Palo Alto PAN-OS	Firewall	0.73	3
IBM DataPower	API Gateway	0.56	2
Juniper SRX	Firewall	0.66	3
Fortinet FortiGate	Firewall	0.64	3
Microsoft AD CS	CA	0.56	2
Custom ACME Client	Cert. Auto.	0.43	2
HashiCorp Vault	Secrets Mgmt	0.30	1
EJBCA	CA	0.27	1
Java JDK 21+	TLS Runtime	0.21	1
AWS KMS	Key Mgmt	0.24	1
Spring Framework	App Framework	0.23	1
Windows CNG	OS Crypto API	0.24	1
Azure Key Vault	Key Mgmt	0.16	1
AWS ACM	Cloud TLS	0.10	1
OpenSSL 3.x	TLS Library	0.10	1
Nginx	Web/TLS Proxy	0.10	1
Apache httpd	Web/TLS Proxy	0.10	1

CAD = 0.10–1.00; Phase 1: 0–12 mo, Phase 2: 12–36 mo, Phase 3: 36–60 mo

V. CAD MEASUREMENT RESULTS

A. Component CAD Scores

Table I lists all 22 components with CAD scores and migration phases. Figure 2 plots the full distribution sorted by CAD score.

B. CAD Dimension Profiles

Figure 3 shows radar charts for four representative components across the CAD tier spectrum. The F5 BIG-IP hardware appliance scores 1.0 on all five dimensions: no PQC algorithm support, hardware- replacement-only change path, key size incompatibility, maximum compliance overhead (PCI-DSS CDE revalidation + CAB), and 36-month procurement cycle. In contrast, OpenSSL 3.x scores 0.1 across all dimensions: PQC via OQS Provider today, configuration-only change, no key size constraint, minimal compliance overhead for a library update.

C. Risk-CAD Prioritization Matrix

Figure 4 plots all components in risk-tier vs. CAD-score space. The upper-right quadrant (Critical/High risk + High/Very High CAD) defines the highest-priority migration targets. F5 BIG-IP hardware sits in this quadrant: 39.3% of SIFI cryptographic endpoints, directly on the CDE TLS termination path, with CAD = 1.00.

D. Estate-Level Analysis

The reference SIFI estate yields: $\mathrm{CAD}_{\mathrm{estate}} = 0.457$ (Medium-High tier), confirming Proposition 1: at least one Phase 3 component exists. The estate phase distribution is

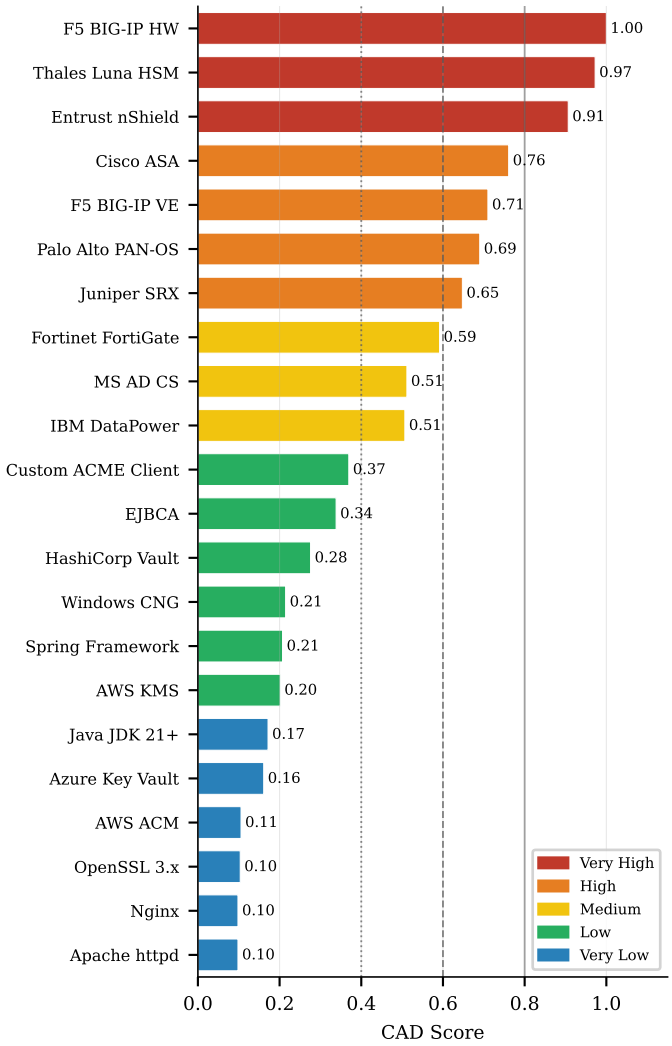

Fig. 2. CAD score distribution across 22 SIFI infrastructure components. Three Very High CAD components (F5 BIG-IP hardware, Thales Luna HSM, Entrust nShield) anchor Phase 3. Six Very Low CAD components (OpenSSL, Nginx, Apache, AWS ACM, AWS KMS, Azure KV) are Phase 1-migratable within 12 months.

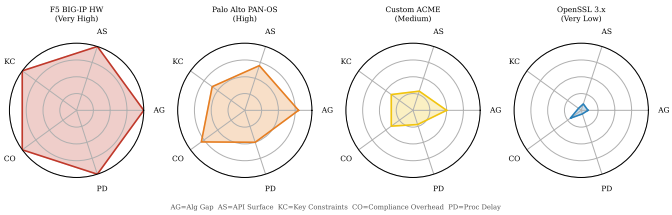

Fig. 3. CAD dimension radar profiles for four representative components. AG=Algorithm Gap, AS=API Surface, KC=Key Constraints, CO=Compliance Overhead, PD=Procurement Delay. F5 BIG-IP HW scores 1.0 on all dimensions; OpenSSL 3.x scores ≤ 0.1.

55.5% Phase 1 endpoints, 5.2% Phase 2, and 39.3% Phase 3. The 39.3% Phase 3 figure is dominated by F5 BIG-IP hardware (22.3%) plus HSMs and legacy firewalls.

This means 39.3% of SIFI cryptographic endpoints *cannot complete PQC migration before 36 months from program initiation*, regardless of security budget or organizational priority—their timelines are set by hardware procurement lead times and

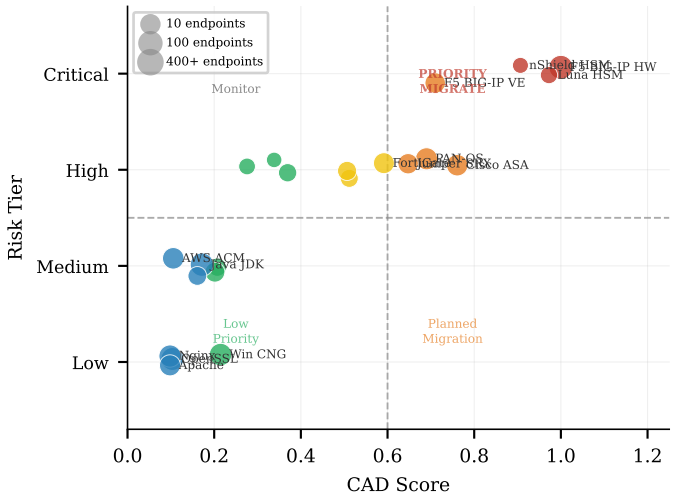

Fig. 4. Risk tier vs. CAD score. Bubble size proportional to log(endpoint count). Upper-right quadrant = priority migration targets. F5 BIG-IP hardware is the dominant concern: Critical risk, CAD = 1.00, 22.3% of estate endpoints.

TABLE II
THREE-PHASE SIFI PQC MIGRATION ROADMAP

Phase	Scope	Timeline	Endpoints
1	Software TLS stacks, cloud services	0–12 mo	55.5%
2	Firmware upgrades, managed CAs	12–36 mo	5.2%
3	Hardware: F5 appliances, HSMs	36–60 mo	39.3%

compliance-gated change management cycles.

VI. Migration Roadmap

Figure 5 shows the three-phase migration roadmap for the reference SIFI estate. Table II summarizes the phase structure.

Phase 1 recommendation. Deploy ML-KEM hybrid key exchange (X25519 + ML-KEM 768) in all software TLS stacks (OpenSSL, Nginx, Apache, Java, Spring) within 12 months. This covers 55.5% of endpoints with minimal compliance overhead and provides harvest-now- decrypt-later protection immediately.

Phase 2 recommendation. Upgrade firmware-updateable components (Fortinet, IBM DataPower, custom ACME clients) and renew CA hierarchies (AD CS, EJBCA) with dual-algorithm certificate chains (classical + PQC).

Phase 3 recommendation (initiate immediately). Issue hardware procurement RFPs for F5 BIG-IP PQC-capable hardware, Thales Luna 10, and replacement HSMs. Phase 3 cannot be accelerated—procurement cycles of 36 months mean that procurement initiated today completes by 3 years from now.

VII. Policy Implications

NIST IR 8547 gap. IR 8547 does not include a quantitative readiness metric or acknowledge hardware procurement as a migration bottleneck. We recommend adding CAD scoring as a mandatory first step in the IR 8547 inventory process, with explicit Phase 3 flagging for hardware components.

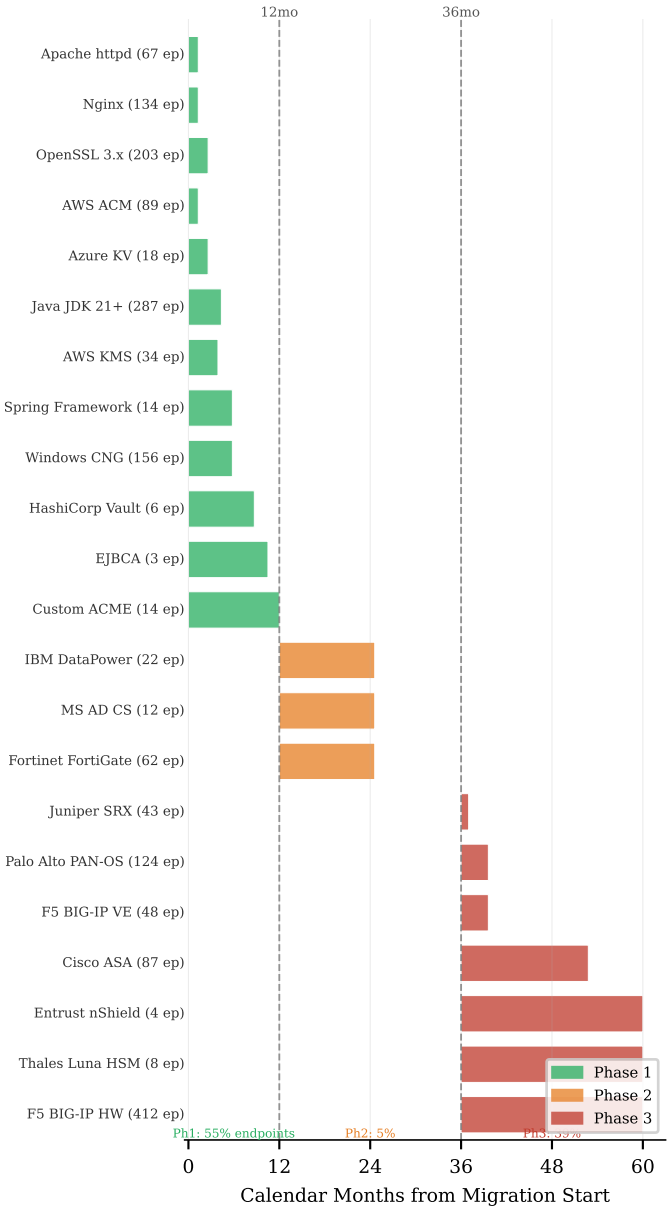

Fig. 5. SIFI PQC migration roadmap by component. Endpoint counts shown in parentheses. Phase 3 hardware components (red) cannot begin meaningful migration until procurement cycles are initiated today.

Financial regulator guidance. OCC, Federal Reserve, and FDIC guidance should establish CAD-score thresholds for regulatory reporting. SIFIs with $\mathrm{CAD}_{\mathrm{estate}} \geq 0.40$ (our reference threshold, validated by Proposition 1) should be required to file a Phase 3 component inventory and hardware procurement timeline with their primary regulator.

F5 Networks and HSM vendors. F5 BIG-IP hardware's Very High CAD (1.00) directly affects 22.3% of SIFI endpoints. F5 should publish a firm hardware PQC roadmap and provide FIPS 203/204 support in VE editions by 2025 to allow SIFI organizations to begin migration path planning.

VIII. Open-Source CAD Assessment Tool

The CAD-Assessor is a Python CLI that evaluates infrastructure components against the CAD rubric in Defini-

tion 2 and generates a migration priority report aligned with NIST IR 8547. The tool:

- Accepts a component inventory (JSON or interactive questionnaire)
- Computes per-component and estate-level CAD scores
- Assigns migration phases and generates a roadmap
- Outputs a NIST IR 8547 compliance gap report in both Markdown and machine-readable JSON

IX. Reproducibility

The CAD model, component dataset, figures, and a GNU Makefile pipeline are released at:

https://github.com/souradeepta/pqc-agility-debt

`make all` runs: component assessment, figure generation, and LaTeX compilation. All numbers in this paper are sourced from `results/results.tex`; no values are hardcoded in the `.tex` file. Component data is in `data/components.json` (sources cited per component).

X. Related Work

PQC algorithm performance. Paquin et al. [12] benchmark NIST PQC candidates; Sikeridis et al. [13] measure TLS handshake performance with PQC hybrids. These papers address algorithm characteristics, not deployment readiness.

Cryptographic agility. Acharya et al. [9] define cryptographic agility for protocol design. Aviram et al. [10] analyze algorithm downgrade attacks. Neither paper addresses the enterprise migration cost dimension.

SIFI operational security. Our ZTRCM framework [14] models ZTA retrofitting cost for SIFI environments. The CAD metric extends that work to the cryptographic algorithm migration dimension, with analogous treatment of hardware procurement and compliance overhead as primary cost drivers.

XI. Conclusion

We introduced cryptographic agility debt (CAD), a five-dimension metric for PQC migration difficulty, and presented the first systematic CAD measurement across 22 SIFI infrastructure components. The F5 BIG-IP hardware appliance (CAD = 1.00, 22.3% of SIFI endpoints) is the dominant migration bottleneck: it requires hardware replacement with 90-month procurement and compliance cycles that cannot be accelerated by security budget. Overall, 39.3% of SIFI cryptographic endpoints carry High or Very High CAD, with 39.3% unable to complete migration before 36 months from program initiation.

Practitioners should initiate Phase 3 hardware procurement *now* and deploy Phase 1 software migrations within 12 months to achieve harvest-now-decrypt-later protection. Regulators should mandate CAD-score reporting for SIFIs with $\mathrm{CAD}_{\mathrm{estate}} \geq 0.40$.

References

[1] NIST, "FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard." NIST Federal Information Processing Standard, 2024.

[2] NIST, "FIPS 204: Module-Lattice-Based Digital Signature Standard." NIST Federal Information Processing Standard, 2024.

[3] NIST, "FIPS 205: Stateless Hash-Based Digital Signature Standard." NIST Federal Information Processing Standard, 2024.

[4] CISA, "Post-Quantum Cryptography Initiative." CISA Publication, 2022.

[5] OMB, "M-23-02: Migrating to Post-Quantum Cryptography." OMB Memorandum, 2022.

[6] NIST, "NIST IR 8547 (ipd): Transition to Post-Quantum Cryptography Standards." NIST Interagency Report, Initial Public Draft, 2024.

[7] Financial Stability Board, "2023 List of Global Systemically Important Banks (G-SIBs)." FSB Publication, 2023.

[8] D. Stebila, M. Campagna, S. Miller, S. Celi, and B. Westerbaan, "Hybrid key exchange in TLS 1.3." Internet-Draft, IETF, 2023.

[9] A. Acharya, V. Iovino, and M. Rosulek, "On the cryptographic agility of systems," in *IEEE Security and Privacy Workshops (SPW)*, 2019.

[10] N. Aviram *et al.*, "DROWN: Breaking TLS using SSLv2," in *Proceedings of the 25th USENIX Security Symposium*, pp. 689–706, 2016.

[11] F5 Networks, "F5 BIG-IP Product Family Overview." F5 Technical Documentation, 2023.

[12] C. Paquin, D. Stebila, and G. Tamvada, "Benchmarking post-quantum cryptography in TLS," *IACR Cryptology ePrint Archive*, vol. 2019, p. 1447, 2019.

[13] D. Sikeridis, P. Kampanakis, and M. Devetsikiotis, "Post-quantum authentication in TLS 1.3: A performance study," in *Proceedings of the Network and Distributed Systems Security Symposium (NDSS)*, 2020.

[14] S. Biswas, "Zero-trust architecture retrofitting in legacy financial network segments: An empirical cost model for SIFI environments," in *Proceedings of IEEE CNS*, 2025.